

ZEROTRACE

SECURITY POLICY

Repository Security • AI-Agent Safety • Secrets • Reporting

Document Purpose

This document defines the security practices and reporting expectations for the ZeroTrace repository. It is intended to protect source code, evaluation infrastructure, credentials, user data, agent configurations, traces and deployment environments.

Security Principles

ZeroTrace should follow least privilege, secure secret handling, input validation, explicit authorization, trace minimization, dependency hygiene, safe error handling and auditable evaluation activity. Security-sensitive capabilities should be isolated from ordinary application flows wherever practical.

Secrets and Environment Variables

Never commit API keys, access tokens, database passwords, private keys or production credentials. Store secrets in environment variables or the secret-management mechanism provided by the deployment platform. Keep a sanitized `.env.example` containing variable names but no real secret values.

Authentication and Authorization

Protected application features should verify authentication before access. Authorization should be enforced on the server for protected resources rather than relying only on frontend navigation. Sensitive evaluation data should be accessible only to authorized users or services.

Input and API Security

Validate request payloads, enforce reasonable size and rate limits where appropriate, reject unexpected inputs, sanitize user-controlled content before rendering, and return safe error messages that do not expose internal secrets or stack traces.

AI-Agent Security

Agent evaluations should use controlled tools and explicit permissions. Tool access should follow least privilege. Evaluation scenarios should not grant destructive production access merely to test behavior. Sensitive prompts, credentials and private data should not be included in adversarial scenarios unless the environment is intentionally isolated and authorized.

Logging and Trace Protection

Logs and traces can contain sensitive prompts, tool parameters, URLs, identifiers or returned data. Collect only what is needed for reliability analysis, protect stored traces, restrict access, and avoid logging credentials or authentication tokens.

Dependency and Deployment Security

Keep dependencies reviewed and updated, use lockfiles, remove unused packages, protect CI/CD secrets, restrict deployment permissions and verify production configuration before release. Do not expose development credentials or debug interfaces in production.

Vulnerability Reporting

Security vulnerabilities should be reported privately to the repository maintainers rather than publicly disclosed in an issue before a fix is available. Include a clear description, affected component, reproduction information where safe, potential impact and suggested mitigation if known.

Recommended Repository Practice

Add a root-level SECURITY.md with the project's actual private reporting channel and supported versions. Do not invent an email address or security contact until one has been officially chosen.

Security Checklist

Area	Required Practice
Secrets	No real secrets in Git; use environment/secret manager
Authentication	Verify identity on protected server-side operations
Authorization	Apply least privilege to users, services and agent tools
Input Validation	Validate and constrain API/user-controlled inputs
Trace Privacy	Minimize and protect sensitive evaluation data
Logging	Never log credentials, tokens or unnecessary private data
Dependencies	Review/update dependencies and retain lockfiles
CI/CD	Protect deployment credentials and branch/release permissions
Errors	Do not expose internal stack traces or secrets
Reporting	Use private disclosure for security vulnerabilities

Security Incident Response

Stage	Action
1. Identify	Confirm the issue and affected component
2. Contain	Restrict exposure or affected functionality where practical
3. Assess	Determine affected data, systems and severity
4. Remediate	Develop, test and deploy a fix
5. Verify	Confirm the vulnerability is resolved
6. Document	Record root cause, impact and corrective action